

■■ PHISHING DETECTION & AWARENESS REPORT

Future Interns — Cyber Security Internship 2026

Task 02 | Phishing Email Analysis & Employee Awareness

Prepared by: Cyber Security Intern | June 2026

3	5+	3	10+
Emails Analyzed	Indicators Identified	Risk Levels Used	Prevention Tips

1. Executive Summary

Phishing is one of the most prevalent and damaging cyber threats facing organizations today. Attackers craft deceptive emails that impersonate trusted entities to trick users into revealing credentials, downloading malware, or transferring funds. This report documents the analysis of three real-world phishing email samples, identifies common attack indicators, classifies risk levels, and provides actionable awareness guidelines for employees.

This task was completed as part of the Future Interns Cyber Security Internship (2026), Task 02: Phishing Email Detection & Awareness System.

2. What Is Phishing?

Phishing is a social engineering attack in which a threat actor sends a fraudulent message — typically via email — that appears to come from a reputable source. The goal is to deceive the recipient into taking a harmful action, such as:

- Clicking a malicious link that leads to a fake login page or malware download
- Opening an infected email attachment (PDF, Word doc, ZIP)
- Entering credentials, OTPs, or banking details on a spoofed website
- Transferring money to an attacker-controlled account (Business Email Compromise)

According to the Verizon DBIR, over 36% of data breaches involve phishing. Most attacks succeed not because of weak technology, but because users are unaware of the warning signs.

3. Analyzed Phishing Email Samples

Sample 1 — Account Suspension Phish

Field	Details
Subject	■■ Urgent: Your Account Will Be Locked
From (Display)	Security Team <no-reply@secure-account-verify.com>
Actual Sender IP	185.234.219.xx (Registered: Russia)
SPF	FAIL — IP not authorized by domain
DKIM	NONE — No signature present
DMARC	FAIL — Policy: reject
Embedded Link	http://secure-account-verify[.]com/login
Risk Level	■ PHISHING

Email Body (Reconstructed):

Dear User,

We noticed suspicious activity on your account. To avoid account suspension, please verify your details immediately.

■ Verify Now: [http://secure-account-verify\[.\]com](http://secure-account-verify[.]com)

Failure to verify within 24 hours will result in permanent account lock.

Regards,
Security Team

Red Flags Identified:

- Spoofed domain — 'secure-account-verify.com' has no relation to any legitimate service
- Urgency language — '24 hours' / 'account lock' to pressure immediate action
- Generic greeting — 'Dear User' instead of the recipient's real name
- HTTP link (not HTTPS) — no SSL certificate on the phishing site
- SPF/DKIM/DMARC all failed — email header authentication completely absent

Sample 2 — PayPal Invoice Scam

Field	Details
Subject	Invoice #INV-9823 from PayPal — Action Required
From (Display)	PayPal Billing <billing@paypa1-service[.]net>
Actual Sender IP	103.76.228.xx (Registered: Singapore)
SPF	SOFTFAIL — Partial mismatch

DKIM	FAIL — Signature invalid
DMARC	FAIL
Embedded Link	https://paypa1-service[.]net/invoice/confirm
Risk Level	■ PHISHING

Red Flags Identified:

- Typosquat domain — 'paypa1-service.net' uses '1' instead of 'l' to mimic PayPal
- Fake invoice attachment — designed to trigger panic about an unauthorized charge
- Mismatched 'From' display name vs actual sender domain
- Link does not point to paypal.com — verified via safe URL inspection
- Urgency — 'Action Required' in subject creates pressure to click immediately

Sample 3 — IT Department Password Reset

Field	Details
Subject	Mandatory Password Reset — IT Department
From (Display)	IT Support <itsupport@company-helpdesk[.]org>
Actual Sender IP	45.33.32.xx (VPS — Linode, USA)
SPF	PASS (spoofed domain set up SPF to pass)
DKIM	PASS (attacker controls the domain)
DMARC	PASS (but domain is not the real company)
Embedded Link	https://company-helpdesk[.]org/reset-password
Risk Level	■ SUSPICIOUS (advanced — passes auth checks)

Red Flags Identified:

- Domain impersonation — 'company-helpdesk.org' is NOT the actual company domain
- Unsolicited password reset — no prior user action triggered this request
- Attacker set up a lookalike domain that passes SPF/DKIM — more sophisticated attack
- Link leads to a credential-harvesting page, not the real IT portal
- Authority pressure — 'Mandatory' and 'IT Department' used to imply compliance is required

4. Phishing Indicators Reference

The table below summarizes the most common phishing indicators found across email samples and widely observed in the wild.

#	Indicator	Description	Severity
1	Spoofed / Typosquat Domain	Domain mimics a real brand (paypa1 vs paypal, arnazon vs amazon)	■ High
2	SPF / DKIM / DMARC Failure	Email authentication checks fail — sender is not authorized	■ High
3	Urgency / Fear Language	'Act now', '24 hours', 'account suspended' — pressure tactics	■ High
4	Mismatched Display Name	Display name says 'PayPal' but actual email is from a random domain	■ High
5	Suspicious Embedded Links	Hover reveals a different URL from what is displayed in the text	■ High
6	Generic Greeting	'Dear User', 'Dear Customer' — legitimate services use your real name	■ Medium
7	Unexpected Attachment	Unsolicited PDF, Word doc, or ZIP — common malware delivery vector	■ High
8	HTTP (No HTTPS) Links	Legitimate services use HTTPS; HTTP links are a red flag	■ Medium
9	Grammar / Spelling Errors	Poor grammar is common in phishing emails from non-native speakers	■ Medium
10	Requesting Sensitive Info	Asking for passwords, OTPs, SSNs via email — never legitimate	■ High

5. Risk Classification

Risk Level	Definition	Action Required
■ SAFE	No phishing indicators detected. Email passes all authentication checks. Sender is on the organization's whitelist.	No action needed. Proceed normally.
■ SUSPICIOUS	Some indicators present but not conclusive. May be a sophisticated attack or a poorly configured legitimate service.	Do not click links or open attachments. Report to IT/Security for further investigation.
■ PHISHING	Multiple confirmed indicators. Clear intent to deceive. Failed authentication. Reported immediately.	Do not interact. Report immediately. Delete the email.

6. How Phishing Attacks Work — Simple Explanation

Here is a simple, step-by-step explanation of how a typical phishing attack unfolds, written so that any employee can understand it — no technical background required.

Step 1 — Attacker Prepares	The attacker registers a fake domain (e.g. paypa1-service.net) and sets up a convincing copy of a trusted website. They write an email designed to create panic — a fake unpaid invoice, a locked account, or an urgent IT notice.
Step 2 — Email Is Sent	The phishing email is sent to thousands of people at once. The attacker uses display-name spoofing to make the 'From' field look like it's from a real company. Most spam filters won't catch a well-crafted phishing email.
Step 3 — Victim Clicks the Link	The email creates urgency: '24 hours to respond or your account will be locked.' The victim, feeling panicked, clicks the link without checking the URL closely.
Step 4 — Fake Login Page	The link leads to a website that looks identical to the real company's site. The victim enters their username and password — which is immediately captured by the attacker.
Step 5 — Attack Succeeds	With the stolen credentials, the attacker logs into the real account. They may steal data, send further phishing emails from the victim's account, or sell the credentials on the dark web.

7. Prevention Guidelines for Users

The following guidelines should be shared with all employees as part of a security awareness programme. Following these steps will significantly reduce the risk of falling victim to a phishing attack.

■ Verify the Sender Domain	Always check the full email address, not just the display name. 'PayPal Billing ' is NOT from PayPal. Legitimate emails from PayPal come from @paypal.com only.
■ Hover Before You Click	Before clicking any link in an email, hover your mouse over it to see the actual URL. If it doesn't match the official website of the claimed sender, do not click.
■ Enable Multi-Factor Authentication (MFA)	Even if an attacker steals your password, MFA prevents them from logging in. Enable MFA on all accounts, especially email, banking, and work systems.
■ Never Share Credentials via Email	No legitimate company will ever ask for your password, OTP, or banking details via email. If an email asks for this, it is a phishing attempt — report it immediately.
■ ■ Pause Before Acting on Urgency	Phishing emails rely on panic. If an email says 'act now or your account is deleted,' pause. Go directly to the official website by typing it in your browser — do not click the link.
■ Don't Open Unexpected Attachments	Never open an attachment you weren't expecting, even if it appears to come from a colleague. Attackers can compromise email accounts and send malware from trusted addresses.
■ Keep Software Updated	Many phishing attacks deliver malware that exploits outdated software. Keep your OS, browser, and antivirus updated at all times.
■ Verify via a Different Channel	If you receive a suspicious email from your bank, IT department, or a colleague asking for something unusual, call them directly using a number from the official website — not from the email itself.

8. Employee Quick Reference — Do's and Don'ts

Print this page and display it near workstations or share it as part of your security awareness programme.

DO's ■

- Verify the sender's full email address before responding
- Check links by hovering before clicking
- Use Multi-Factor Authentication on all accounts
- Report suspicious emails to your IT / security team
- Go directly to official websites by typing the URL
- Keep your software and antivirus up to date
- Attend security awareness training regularly
- Verify unusual requests via phone using official numbers

DON'Ts ■

- Do NOT click links in unexpected or suspicious emails
- Do NOT open unexpected email attachments
- Do NOT share your password or OTP via email
- Do NOT act immediately on urgency-based emails
- Do NOT use the same password across multiple accounts
- Do NOT ignore security warnings from your browser
- Do NOT forward suspicious emails to colleagues
- Do NOT assume an email is safe because it passed your spam filter

9. Conclusion & Recommendations

This report analyzed three phishing email samples and identified a consistent set of attack techniques — including domain spoofing, urgency language, and authentication failures. While technology controls like SPF, DKIM, and DMARC provide a strong first line of defence, they are not infallible, as demonstrated by Sample 3 where the attacker configured a lookalike domain to pass all authentication checks.

The most effective defence remains a well-informed workforce. Organizations should implement the following measures:

- Deploy mandatory phishing awareness training for all employees (minimum annually)
- Conduct regular simulated phishing exercises to measure and improve employee awareness
- Implement email gateway filtering with SPF/DKIM/DMARC enforcement
- Enable Multi-Factor Authentication across all corporate systems
- Establish a simple, well-publicized process for employees to report suspicious emails
- Create an incident response plan for suspected phishing attacks

Remember: Phishing attacks succeed because of human error, not just weak systems. A single click can compromise an entire organization. Stay vigilant, verify before you click, and always report suspicious emails.